DRAFT — PENDING OWNER APPROVAL

AutoClip — Personal Information Protection Standard

Document status: Draft for owner and privacy/legal review. This document is not effective until formally approved. **Version:** 1.2-draft **Document owner:** MEI holder / accountable business operator: 56.151.919 DIOGO NASCIMENTO DOS SANTOS **Approver:** Pending owner decision; no approval is recorded **Approval date / effective date:** Not approved; to be completed only after owner approval **Next review:** One year after approval, and after a material incident or processing change.

> This standard defines AutoClip's intended requirements for protecting personal information. Its existence does not prove that every requirement is implemented, deployed, monitored, legally approved, or independently audited. Current evidence and open gaps are listed in `SECURITY_CONTROL_EVIDENCE_MATRIX.md` and `COMPLIANCE_GAPS_AND_ACTIONS.md`.

1. Document Control

Business identity: AutoClip is the trade name of **56.151.919 DIOGO NASCIMENTO DOS SANTOS**, an individual micro-entrepreneur (MEI) registered in Brazil (CNPJ **56.151.919/0001-30**), based in Rio de Janeiro/RJ. The business is operated by the MEI holder. Contact: **diogos.nascimento@outlook.com**. This contact is owner-provided; mailbox monitoring has not been independently verified.

AutoClip is the service name, not a separate legal entity. The MEI holder is the accountable business operator. Controller/processor roles must be determined for each processing activity and contractual relationship; this standard does not designate the operator as controller for every data flow. The business opening date recorded in the owner-provided CCMEI is 30 July 2024. No CPF or residential street address is included.

The project owner shall approve the document, confirm the responsible legal entity/operator, set the effective date, designate operational owners, and retain the approval record in a controlled evidence location. Only the approved version may be represented externally as an effective organizational standard. Revision history shall identify the version, date, approver, and substantive changes. No signature or approval is implied by this draft.

2. Purpose

This standard establishes requirements for collecting, using, protecting, retaining, and disposing of personal information processed by AutoClip. It supports the protection of account holders, workspace members, TikTok and TikTok Shop account holders, and other people whose information may appear in content or permitted platform data. It is an internal control document, not a certification or legal opinion.

3. Scope

The standard applies to AutoClip application code, databases, authentication, object storage, Edge Functions, workers, source repositories, operational accounts, support processes, and third-party services used to operate the service. It applies to production, staging, development, and test environments; synthetic data shall be used in tests unless an approved exception is documented. The checkout and billing flow is outside the current deployment scope; this does not authorize collecting payment-card information.

4. Roles and Responsibilities

- **Project owner / accountable operator:** approves this standard, assigns security and privacy responsibilities, authorizes production changes, and ensures that evidence is current.
- **Security incident lead:** coordinates triage, containment, investigation, notification assessment, recovery, and corrective actions under the incident runbook. The individual and backup coverage require owner confirmation.
- **Engineering and operations:** implement least privilege, secure coding, deployment controls, monitoring, access reviews, and incident actions within approved authority.
- **Workspace owners and administrators:** manage workspace membership and content only within their authorized workspace and purposes.
- **Personnel and service providers:** access information only for assigned duties, preserve confidentiality, and promptly report suspected incidents.

The MEI holder is the accountable business operator. The privacy and security contact supplied for this document is diogos.nascimento@outlook.com; active monitoring and response coverage are not verified. The owner shall record any additional named role-holders and alternates in an access-controlled operational register.

5. Personal Information Inventory

The local schema and application source indicate that AutoClip may process:

Category	Examples in local design	Protection requirement
Account and identity	Auth user identifiers, email managed by Supabase Auth, profile display name	Restrict to account and support purposes; do not copy Auth data into

Category	Examples in local design	Protection requirement
		evidence reports
Workspace and access	Workspace name, owner/member IDs, role, membership history	Enforce workspace authorization; limit administrative access
Connected social accounts	TikTok provider user ID, display name, creator/shop identifiers, granted scopes and connection status	Use only to connect and operate the account selected by the user
OAuth credentials	Access and refresh tokens, expiry and authorization state	Treat as secrets; encrypt before persistence; never expose in browser or ordinary logs
User content and publication	Media, file names, tags, captions, privacy settings, schedules, publication IDs/status/history	Treat content and metadata as potentially personal or confidential; isolate by workspace
Shop data	Product titles/descriptions/URLs, product identifiers, shop identifiers; local schema also defines order identifiers, amounts, statuses and raw JSON fields	Minimize fields; review raw payloads before any operational use; do not assume no buyer information is present
Operational/ security records	Audit events, request outcomes, error codes, worker/job states and timestamps	Minimize identifiers and error content; restrict access and retention
Technical data	Request, device, IP, and diagnostic data may be generated by providers or application infrastructure	Actual fields, provider retention, and access must be inventoried from deployed settings

The inventory is based on local migrations and code only. It does not prove that all listed objects are deployed or that the current Cloud payloads contain only these fields. User-provided media and captions may contain personal information about third parties. The local TikTok Shop schema includes `raw jsonb` fields; field-level minimization and the actual API payloads require review before enabling synchronization of orders or other sensitive data.

6. Data Collection and Processing Principles

AutoClip shall collect only information necessary for the requested account, workspace, scheduling, publishing, support, security, and legal purposes. Processing shall be purpose-limited, access-controlled, accurate where practicable, and retained only according to an approved schedule. Production data shall

not be used for development or testing without a documented, approved de-identification process. The project shall maintain a data-flow and subprocessor inventory and update it before introducing a new category or purpose.

7. Lawful Processing and Privacy Commitments

For Brazil-related processing, the operator shall assess applicable duties under the LGPD with qualified legal advice. The operator/controller/processor role is activity-specific and must be determined from the actual purposes, decisions, contracts and instructions for each flow. The existence of this draft is not proof of LGPD compliance or formal adoption.

Before processing personal information, the accountable operator shall document the purpose, applicable legal basis, transparency notice, relevant platform permission, and any transfer or processor requirements. Requests to access, correct, export, restrict, object to, or delete information shall be authenticated and assessed under applicable law and contract. This standard does not assert full LGPD or other legal compliance; qualified legal review is required for jurisdiction-specific conclusions, international transfers, retention exceptions, and regulatory notification duties.

8. Access Control

Access shall be individually attributable, role-based, limited to the minimum required, and removed promptly when no longer needed. Workspace data shall be scoped to the authenticated user and authorized workspace. Privileged service credentials shall remain server-side and shall not be embedded in browser bundles, source control, screenshots, or support tickets. Administrative access shall use named accounts, strong authentication, and periodic review. Emergency access shall be time-bounded, approved, logged, and reviewed afterward.

Local migrations and tests provide source-code evidence for workspace roles and RLS behavior. They do not prove the currently deployed policies, grants, administrator roster, or production enforcement. Those settings must be verified separately before external claims are made.

9. Authentication and Administrative Security

Authentication shall use the approved identity provider and secure session handling. Administrative and provider-console accounts shall use MFA where supported, unique credentials, recovery controls, and restricted membership. MFA status for the actual Supabase, Vercel, source-control, email, and TikTok Shop accounts is not established by this repository and must be verified by the owner. Passwords, recovery codes, API keys, private keys, and OAuth tokens shall never be requested in chat or stored in this repository.

10. Data Segregation and Multi-Tenant Isolation

Every tenant-owned record and object shall be associated with its workspace and protected against cross-workspace reads, writes, exports, signed URLs, and deletion. Database policies, foreign keys, RPC authorization, Edge Function checks, and Storage policies shall agree on the workspace boundary. Tests shall include unauthorized users, removed members, role changes, malformed identifiers, and attempted cross-workspace references. Local tests are not proof of production configuration; Cloud verification and isolated runtime tests remain required.

11. Encryption and Secure Communications

Production interfaces shall use TLS with certificate and hostname validation. Secrets and credentials shall not be transmitted over unapproved destinations. Token-bearing database values shall be encrypted before persistence with authenticated encryption and connection-specific associated data; encryption keys shall be stored separately in a protected server-side secret store, access-limited, and rotated under a documented procedure. Provider-managed encryption at rest for database, backups, and object storage must be confirmed from applicable provider evidence; repository code alone cannot establish it.

12. Credential and OAuth Token Protection

OAuth authorization shall validate state and the exact registered callback. Access and refresh tokens shall be handled only by trusted server-side components, encrypted at rest, excluded from application responses, telemetry, traces, error messages, and logs, and bound to the correct workspace/connection. Refresh operations shall use single-writer coordination, attempt/version checks, atomic persistence of the new token set, and conservative handling of ambiguous provider responses. An invalid or uncertain refresh credential shall require reauthorization rather than blind replay.

The local Login Kit implementation and M10/M11 migrations have local tests, but Cloud deployment is unverified. Gate 3.19.3 also recorded that a legacy direct writer could bypass the newer compare-and-swap path; therefore complete single-writer enforcement remains unproven until old writers are drained or made compatible and verified. TikTok Shop has a distinct authorization contract. Its TTL, rotation, invalidation, and effective date have not been confirmed from accessible official material; do not claim Shop OAuth compliance with Login Kit rules until confirmed for the actual Shop authorization type.

13. Secure Development Lifecycle

Security-relevant changes shall receive peer or independent review, static analysis where available, targeted negative tests, dependency review, and isolated integration tests before release. Database migrations shall be reviewed for tenant boundaries, privilege changes, lock impact, data preservation, and rollback/roll-forward behavior. Secrets and production data shall not be included in fixtures. A passing local test suite shall not be described as Cloud deployment or end-to-end provider validation.

14. Vulnerability and Dependency Management

The project shall maintain an asset/dependency inventory, monitor security advisories, triage findings by severity and exploitability, assign remediation owners and deadlines, and verify fixes. Dependency scans shall cover each runtime and package ecosystem used, including Deno/JSR where applicable. A historical npm audit result does not establish current status for every dependency or deployed artifact. Exceptions require written risk acceptance, compensating controls, an owner, and an expiry/review date.

15. Logging and Monitoring

Security and operational logs shall support investigation while minimizing personal information. Logs shall not contain plaintext tokens, authorization codes, secrets, passwords, full credential-bearing URLs, media contents, or unnecessary customer data. Access to logs shall be restricted and retention documented. Monitoring shall cover authentication anomalies, access-control failures, token refresh and reauthorization failures, worker/job errors, publication reconciliation, suspicious tenant-boundary events, and service availability. Runtime log configuration, alert coverage, retention, and mailbox monitoring require operational verification.

16. Incident Detection and Response

Suspected unauthorized access, disclosure, loss, alteration, credential compromise, cross-tenant access, malware, or material availability events shall be reported promptly through an owner-confirmed channel. The incident lead shall record a sanitized incident record, preserve relevant evidence, contain the affected workflow, assess affected systems and individuals, determine notification duties, recover safely, and track corrective actions. Notification timing shall follow applicable law, contract, and TikTok Shop requirements. The local `docs/INCIDENT_RESPONSE_RUNBOOK.md` describes a process, but monitoring, register operation, assigned backup coverage, tabletop exercise completion, and response readiness are not evidenced here.

17. Personal Data Retention

The project shall approve a retention schedule by data category, purpose, and legal/contractual exception. The schedule shall define trigger events, periods, deletion method, backup treatment, and evidence. No comprehensive approved retention schedule was found in the repository. Local media cleanup logic exists, but it is configurable and its production status and activation are not verified. No retention period shall be invented or represented as enforced without configuration and evidence.

18. Data Deletion and Disposal

Verified deletion requests shall be handled through an owner-approved workflow that verifies identity, scopes the request across Auth, workspace records, OAuth credentials, Storage objects, logs, caches, and

provider-side data, applies legal holds where justified, and records completion without retaining unnecessary personal information. Workspace deletion and physical media cleanup shall be separately controlled and tested for shared references and pending/unknown jobs. The repository contains a public-facing deletion-page source and a server-side administrative account-deletion path; deployed availability, actual completion time, third-party deletion, backups, and all-object cleanup are not independently verified. Published content already sent to TikTok remains subject to TikTok's controls.

19. Backup and Recovery

Backups shall be access-controlled, encrypted where supported, monitored, and protected against unauthorized alteration. Recovery objectives, backup scope (database, Storage objects, configuration, and secrets), restoration ownership, and evidence shall be documented and tested periodically. The latest Gate 3.19.3 disposable backup file creation passed, but restore attempts failed; successful recovery is therefore **not verified**. Earlier local restore evidence applied to an earlier schema and does not close the current gap. No production backup or Cloud recovery claim is made.

20. Third-Party Service Providers

The local architecture references Supabase, Vercel, TikTok, and TikTok Shop. Before production processing, the accountable operator shall maintain a subprocessor/provider register with service, purpose, data categories, region/transfer assessment, contract/DPA status, access model, incident contact, retention/deletion terms, and exit strategy. Provider contracts, deployed regions, actual data residency, and current account configuration are not established by local code.

21. Data Subject Requests

Requests shall be received through an owner-confirmed contact channel, identity-checked proportionately, assigned a case identifier, assessed for scope and lawful exceptions, fulfilled within applicable deadlines, and recorded with minimal data. The requester shall receive a clear response. The existing deletion page instructs users to email from the account address and says identity is verified; the channel's active monitoring and workflow completion are not verified. Access, correction, and export procedures are not evidenced as complete operational workflows.

22. Security Training and Responsibilities

People with access to personal information or production systems shall receive role-appropriate onboarding and periodic instruction on least privilege, secrets, phishing/account compromise, incident reporting, data requests, and secure handling of media and OAuth credentials. Training attendance, content, and acknowledgement records must be maintained. No training evidence was found during this local review.

23. Periodic Review

The owner shall review this standard at least annually and after material changes to data collection, providers, authorization scopes, storage, retention, deployment architecture, or applicable law. The review shall confirm that public notices, actual deployed behavior, data inventory, retention schedule, subprocessor register, and incident contacts remain consistent. The review date, reviewer, decisions, and open actions shall be retained.

24. Exceptions and Remediation

Exceptions shall identify the requirement, business reason, affected data/systems, threat assessment, compensating safeguards, accountable approver, owner, expiry, and remediation plan. High-risk privacy or security exceptions shall block the affected processing until reviewed and approved. No exception may silently override provider terms, user authorization, or applicable law.

25. Approval and Version History

Version	Date	Change	Author/reviewer	Approval
1.0-draft	2026-11-02	Initial TikTok Shop review draft based on local repository evidence	Historical author not confirmed	Pending
1.1-draft	2026-11-02	Clarified the legacy OAuth writer limitation and that the single-writer guarantee is not established	Project documentation review	Pending
1.2-draft	2026-11-02	Added owner-provided MEI identity/contact and activity-specific controller/processor qualification; no controls promoted to deployed status	Local document update	Pending owner approval

Approval record: Legal operator: 56.151.919 DIOGO NASCIMENTO DOS SANTOS (MEI holder) · Approver: pending owner decision · Approval/effective date: pending · Publication location: not verified. Contact: diogos.nascimento@outlook.com (monitoring not verified).